SYSTEMS ARCHITECTURE · AUDIT REPORT

Teafair Mobile App — Audit and Front-End Specification

React Native (Expo) client for field sales, shop owners and Monvelo agents: authentication, role workspaces, the market-maker allowance, exposure and reconciliation.

DOCUMENT	VERSION	DATE	CLASSIFICATION
TF-RPT-MOB-001	**1.0**	**2026-11-03**	**Internal — Confidential**

SCOPE OF THIS DOCUMENT

Audits the backend at migration 20261031121100 (A6 §20, R78) and specifies the mobile client that will consume it.

An input to Spec B, not Spec B. Items marked Proposal need the owner's decision; everything else is quoted from the schema and the approved specs.

108
migrations read

234
SQL functions parsed

3,577
pgTAP assertions

Contents

1. Executive Summary 4

1.1 What the app must do 4
1.2 Key audit findings 4

2. Audit Baseline and Method 6

2.1 Audit baseline 6
2.2 Method 6
2.3 Rules every client inherits (Spec A §9) 6

3. Client Architecture 8

3.1 The request path 8
3.2 Offline queue (Spec A §7, locked) 8
3.3 Read cache 8
3.4 Error contract 9

4. Authentication and Security Stack 10

4.1 What the backend provides today 10
4.2 Proposal: two sign-in experiences on one mechanism 10
4.3 Secure storage 11

5. Roles, Navigation and Persona Workflows 13

5.1 Roles in the schema 13
5.2 Workspaces 13
5.3 Street recruitment and Monvelo initialisation (ZSA and ASA) 13

6. Monvelo Market-Maker Allowance UI 15

6.1 Who sees what 15
6.2 Component: HoldCard and the countdown 15
6.3 Component: readiness and credit badges 16
6.4 Component: the decision sheet 16
6.5 Four-eyes segregation of duties (choice 2A) 17
6.6 Hold result contract 18

7. Agent Exposure and Reconciliation Views 19

7.1 How open exposure is computed (A6 §19.4.1, §20 call 4) 19
7.2 The exposure meter (component spec) 19
7.3 Gap G1: no read path for exposure 20
7.4 Weekly lender reconciliation (get_lender_reconciliation_summary) 20

8. Trade Orders, Packs and Owner Codes 22

8.1 Break-bulk in the app 22
8.2 Delivery and repayment codes 22

9. Design System and Accessibility 23

10. Audit Findings and Gaps 24

11. Appendix A — Mobile RPC Contracts 25

11.1 Session and identity 25
11.2 Street agents and recruitment 25
11.3 Monvelo agents 26
11.4 Market makers 27
11.5 Delivery and owners 28
11.6 Reconciliation 28

12. Appendix B — Enumerations, Statuses and Jobs 30

12.1 Enumerations and status sets 30
12.2 Scheduled jobs the app depends on 30
12.3 Gateways used by the app 30

SECTION 1

Executive Summary

This document audits the Teafair backend as it stands in the local migrations and turns it into a front-end specification for the Teafair mobile app: the React Native (Expo) client that ZSMs, TMs, ZSAs, ASAs, shop owners and Monvelo agents will carry. The backend is complete through Monvelo Step 3, the ₦1,000,000 open exposure cap and the market-maker allowance (A6 §19.4 and §20). No client exists yet.

> **STATUS OF THIS DOCUMENT**
>
> **This is an input to Spec B, not Spec B.** Spec B (the app shell) is on hold until the owner asks for it, and no front-end code or scaffolding is written before it is approved. Everything here marked **Proposal** is a recommendation for Spec B to accept, change or reject. Everything marked as backend fact is quoted from the migrations or the approved specs.
>
> **Platforms:** Android and iOS (the owner's 2026-10-08 decision, which amends Spec A §2 item 11, "Android only at launch").

1.1 What the app must do

- **Sign people in on their verified phone** with a WhatsApp code, select the active tenant, and keep the session in secure storage.
- **Queue every write offline** with an idempotency key fixed when the user acts, and drain it in order when the signal returns (Spec A §7).
- **Give each role its own workspace:** field managers (ZSM, TM, ASM), street agents (ZSA, ASA), shop owners, and the members of Monvelo financing agents.
- **Run Monvelo end to end on the phone:** shop consent, supply days, pledges, trade orders and financing requests, claims, funding over Paystack bank transfer, the delivery and repayment codes the shop owner reads out, and the 15-minute market-maker hold.
- **Show money accurately and never stale:** the agent's open exposure against the ₦1,000,000 cap, and the weekly lender reconciliation grouped by Lagos week.

1.2 Key audit findings

The brief behind this document set out several expectations. Six of them differ from what the schema actually does. The app must follow the schema, so each difference is resolved below and in Section 10.

#	The brief expected	The schema does	Resolution
F1	ZSA and ASA as the Monvelo deciders.	Market makers are the ZSM and the ASA (A6 §20.2 decision 1). The ZSA recruits and raises requests, and reads the lender summary, but cannot allow a hold.	The ZSA build gets no hold queue.

#	The brief expected	The schema does	Resolution
F2	Client-side four-eyes enforcement.	Four eyes is enforced in the database: the raiser and any member of the held agent get 42501 and never see the hold (decision 6, R78).	The client only reflects the rule; it is never the control.
F3	A live exposure meter.	monvelo_agent_open_exposure and both ceilings are ungranted. No RPC returns an agent's open exposure to the app.	**Gap G1: a read RPC is needed before the meter can be built (§7.3).**
F4	Password login for field roles, PIN login for shop owners and agents.	The only sign-in route built is the phone + WhatsApp code for everyone. Email serves recovery and invites; passwords are at least 12 characters. The 4-digit PIN is a transaction control, not a login.	Proposal in §4.2; the login method is an open Spec B decision.
F5	Break-bulk pricing on the web.	Break-bulk applies only to app (trade) sales, at the wholesale price; the web sells single units at retail.	Covered here in §8.
F6	One "POS agent" persona.	There are two: the web POS_AGENT tenant role (referral links, no Monvelo) and the Monvelo agent, a platform entity whose members are people.	They get separate workspaces, and web never touches Monvelo (A6 §15).

Table 1. Brief versus schema: the differences this specification resolves.

SECTION 2

Audit Baseline and Method

2.1 Audit baseline

This document was generated on 2026-11-03 directly from the repository's local migrations. Every function signature, EXECUTE grant, enum value, status set and cron job quoted in the appendices is parsed from supabase/migrations at build time, so the document and the schema cannot drift apart silently: re-running the generator re-reads them.

Item	Value
Migrations read	108 files, 20261006120000 → 20261031121100
Latest migration	20261031121100_monvelo_exposure_limits_scaled.sql
Public SQL functions	234 (latest definitions), of which 112 are executable by authenticated
pgTAP coverage	3,577 assertions in 64 files
Edge Functions	32 gateways in supabase/functions
Scheduled jobs (pg_cron)	11 active jobs
Governing documents	Spec A (2026-10-05) and addenda A1–A6, including A6 §19.4 and §20 (2026-11-02)
Deployment state	The remote project holds the 29 migrations to 20261015130200 (A1, A2). Everything after, including all of Monvelo, is built and tested locally and is not pushed.
Audience	Spec B authors, mobile engineers, QA, product owners for Monvelo and field sales.

2.2 Method

- **Contracts** were parsed from the migrations by the generator (docs/reports/generator/lib/schema.mjs): the latest create or replace function per name, EXECUTE grants net of revokes and drops, enums with added and renamed values, CHECK status sets and pg_cron jobs.
- **Behaviour** was taken from Spec A, addenda A1–A6 and the rulings recorded in supabase/CLAUDE.md (R1–R78), which the pgTAP suite tests.
- **Front-end proposals** follow the locked decisions: React Native + Expo + TypeScript, NativeWind with the teafair-* tokens from FIGMA.md, Zustand, an MMKV queue and read cache.

2.3 Rules every client inherits (Spec A §9)

These rules are enforced in the database and the gateways. A client cannot weaken them; it can only fail to respect them and receive an error. Each one shapes a front-end decision.

Rule	What the client must do
No direct client writes. authenticated has SELECT only; every mutation is a SECURITY DEFINER RPC.	Never call .insert(), .update() or .delete() through supabase-js. Every write is rpc() or a gateway POST.
The tenant comes from the JWT, re-verified live against tenant_users.	Never send a tenant_id parameter. Switching tenant calls set_active_tenant and then refreshes the session so the access-token hook re-issues claims.
Gateways forward the caller's JWT, never the service-role key, for user work.	Send Authorization: Bearer <user JWT> to every /functions/v1/<name> call. No service key ever ships in an app or a browser bundle.
Every mutation takes p_idempotency_key uuid first, generated at enqueue time.	Generate the UUID when the user acts, store it with the queued mutation, and resend the same key on every retry.
Contact privacy: buyer contacts live only in order_contacts; bvn_nin_hash only in user_secure_profiles.	Never cache another person's phone or identity number on the device. Screens show what the RPC returns and nothing more.
Workflow statuses are text + CHECK; stable sets are enums.	Treat status strings as an open set in the UI: render unknown values with a neutral badge instead of crashing.
Money is NUMERIC(15,2), quantities NUMERIC(14,3), timestamps timestamptz.	Parse money as strings into a decimal type; never float arithmetic. Render times in Africa/Lagos from server timestamps.

Table 2. Database rules and their front-end consequences.

SECTION 3

Client Architecture

3.1 The request path

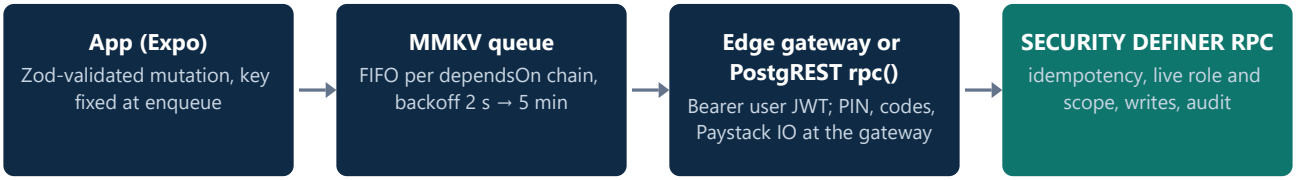


Figure 1. Every write takes this path. The tenant is never a parameter.

Two transports reach the database. **Gateways** (/functions/v1/<name>) are used whenever the operation needs a PIN, a one-time code, Paystack, WhatsApp or Storage. **Direct RPCs** (supabase.rpc()) are used for pure database work, such as claim_monvelo_financing, decide_monvelo_claim_hold and get_lender_reconciliation_summary. Both carry the user's JWT.

3.2 Offline queue (Spec A §7, locked)

```
type QueuedMutation = {
  id: string            // UUIDv4: IS the idempotency_key, generated at enqueue
  operation: string     // gateway function or RPC name
  payload: unknown      // Zod-validated at enqueue, before it ever leaves
  dependsOn?: string    // ordering within a causal chain
  attempts: number
  nextAttemptAt: number
  lastError?: { code: string; message: string; terminal: boolean }
  status: "PENDING" | "IN_FLIGHT" | "TERMINAL" | "DONE"
}
```

- **Retry** on 503 and network failure with the same key. **Stop** on 409 and 422, and move the entry to a visible "Needs attention" list.
- **Online-only operations** must not be queued. These are PIN-gated calls, code entry (delivery and repayment codes, consent codes), funding (monvelo-fund), hold decisions and claims. A claim or a decision that lands after its 15-minute window is worthless, so the UI disables these actions offline and says why.
- **One exception, by design:** log_retail_pickup lands as PENDING_CONFIRMATION with no PIN, and the shop owner confirms it later (Spec A §7.4).

3.3 Read cache

Class	Examples	TTL	Refresh
Master data	products, territories, areas, shops on my beat	long	on app foreground
Operational lists	my trade orders, open offers, hold list	short	on screen focus; pull to refresh

Class	Examples	TTL	Refresh
Money	exposure, pledges, outstanding, reconciliation	never served stale	spinner, or an explicitly stale-marked value with its time
Countdowns	hold, claim and payment windows	not cached	derived from server expires_at (§6.3)

Table 3. Read-cache classes (Spec A §7.5) with the Monvelo additions.

3.4 Error contract

RPC errors carry a SQLSTATE; gateways map them to HTTP. The client maps both to one of three behaviours: show and stop, retry, or re-authenticate.

SQLSTATE / HTTP	Meaning	Client behaviour
42501 / 403	Not allowed: wrong role, out of scope, not a member, the request's raiser deciding its own hold.	Show a neutral "not available to you" message. Do not retry. Refresh the role cache.
P0001 / 422	A business rule refused the action (the message is written for people, e.g. the exposure-cap sentence).	Show the server message verbatim. Move a queued entry to "Needs attention".
22023 (PostgREST 400)	Invalid parameter on a direct RPC (a reason under 10 characters, p_weeks outside 1–52, p_allow null). Not in the gateway contract.	Validate on the client first so this is rare; show the message beside the field.
23505 / 409	Conflict (e.g. a duplicate the database refuses).	Show and stop; refresh the affected list.
TF001 / 409	Insufficient stock; details carry {sku_code, available, requested}.	Offer to reduce the quantity to available.
TF002 / 409	Idempotency key reused with a different payload.	Terminal. Never generate a new key silently for the same user action.
40001, 55P03 / 503; network failure	Transient (serialisation, lock timeout, no signal).	Retry with exponential backoff, 2 s to 5 min, same idempotency key.
PGRST301 / 401	Session expired between the gateway check and the RPC.	Refresh the session once; on failure, return to sign-in and keep the queue.

Table 4. Error mapping (Spec A §3.5, §7.3; supabase/functions/_shared/core/errors.ts).

SECTION 4

Authentication and Security Stack

4.1 What the backend provides today

Mechanism	Backend fact	Where
Phone sign-in	Supabase Auth phone OTP. The Send SMS hook (send-auth-sms) sends the code over WhatsApp only (teafair_otp template), and only when auth_sms_allowed holds: the account's own verified profile phone, plus a platform role or an ACTIVE or INVITED membership. Twilio is never used. An optional KudiSMS fallback is controlled by AUTH_OTP_SMS_FALLBACK.	M1, 20261024170000_auth_hooks
Account creation	Self-serve sign-up is off. Accounts are created through the Admin API with a confirmed phone. invite_tenant_user finds only confirmed phones (H1).	20261024150000
Email	The Send Email hook (send-auth-email, Resend) sends recovery, signup, invite and email-change mail. Magic links, email OTP and reauthentication are refused. Passwords are at least 12 characters, and the reset page is /reset-password.	auth hardening
Tenant claims	The Custom Access Token Hook (auth-verify-claims) puts active_tenant_id and the roles in app_metadata. set_active_tenant(p_idempotency_key, p_tenant_id) proposes a switch; the database checks membership live.	Spec A §5
Transaction PIN	A 4-digit PIN, bcrypt-hashed in tenant_users.pin_hash, verified at the gateway (requirePin). Five failures lock it for 15 minutes. A single-use pass lasts 60 s, so calling the RPC directly still needs the PIN.	Spec A §5.5
Owner codes	6-digit codes drawn by the database (issue_otp, rejection-sampled, bcrypt-stored). They are sent over WhatsApp to the owner's verified phone and never returned to the client. Monvelo delivery and repayment codes follow the same pattern.	H2; A6 §19

Table 5. Authentication building blocks in the backend.

4.2 Proposal: two sign-in experiences on one mechanism

The brief asked for passwordless login for shop owners and POS agents and password login for internal field roles. Spec A leaves the login method open, so this is a Spec B decision. The recommendation keeps **one server mechanism** (phone + WhatsApp code), already hardened and tested, and changes only how often each persona must sign in again and what guards each action.

Persona	Sign-in	Re-authentication	Action guard
Shop owner (RETAIL_SHOP_OWNER)	Phone + WhatsApp code	Long session; biometric unlock of the stored session	Owner codes read out to the deliverer or recorder; PIN where Spec A requires it (record_dsa_stock_issue)
Monvelo agent member	Phone + WhatsApp code	Biometric unlock; code again after 7 days idle (proposal)	Funding is bank transfer from the bound account (payer binding F1)
Street agents (ZSA, ASA), DSA	Phone + WhatsApp code	Biometric unlock; code again daily (proposal)	PIN for deferred pickups and PIN-gated calls
Managers (ZSM, TM, ASM, DSM), CSM, LM, TENANT_ADMIN	Phone + WhatsApp code; optional email + password (≥ 12 characters) as a second factor if Spec B adopts it	Session no longer than one working day	PIN for approve_requisition at TM/ZSM, set_brand_approval_policy, adjust_inventory

Table 6. Proposal for Spec B. The password column needs an owner decision: today email is a recovery and invite channel, not a sign-in route.

DECISION NEEDED BEFORE SPEC B

A password login for field roles would make email a sign-in route. Today the backend deliberately refuses email OTP and magic links. Enabling passwords means accepting email + password at the Auth layer and writing a rule for who may use it. If the goal is a stronger factor for managers, the recommended route is the existing transaction PIN plus a short session, not a second login path.

4.3 Secure storage

Data	Store	Rule
Supabase session (access and refresh token)	**Expo SecureStore (Keychain / Android Keystore), as the supabase-js storage adapter**	Never in MMKV, AsyncStorage or logs. Cleared on sign-out and on a 401 that refresh cannot fix.
MMKV encryption key	SecureStore, generated on first launch	MMKV opened with encryptionKey. The queue holds business payloads, so it is encrypted at rest.
Offline queue and read cache	**MMKV (src/store/mmkvStorage.ts, Spec A §7.1)**	Bounded: a few thousand rows. Money is never served stale.
PIN, owner codes, consent codes	**Nowhere**	Typed, sent once, cleared from state. Never cached (Spec A §7.4: caching a verifier defeats the control).
Other people's contact details	**Nowhere**	Buyer contacts and owner phones never reach the app, except where an RPC returns them to the ZSM or TM.

Data	Store	Rule
Device registration	register_device(p_idempotency_key, p_hardware_id, p_device_model, p_push_token)	Called after sign-in and on push-token rotation.

Table 7. Where each class of secret lives on the device.

- **Sign-out** wipes SecureStore, the MMKV cache and Zustand state. Queued entries are kept but parked until the same profile signs in again. They are never replayed under another user.
- **Tenant switch** drains or parks the queue first, because each entry was enqueued under a tenant claim.
- **Screenshots:** block them (Android FLAG_SECURE, iOS overlay on background) on the code-entry, funding and reconciliation screens.

SECTION 5

Roles, Navigation and Persona Workflows

5.1 Roles in the schema

Enum	Values
`tenant_role_enum`	ZSM, TM, ASM, DSM, DSA, POS_AGENT, RETAIL_SHOP_OWNER, ZSA, ASA, CLIENT_SERVICE_MANAGER, TENANT_ADMIN, LOGISTICS_MANAGER
`platform_role_enum`	PLATFORM_SUPER_ADMIN, MONVELO_OPERATOR, MONVELO_FINANCE

The field force is Teafair staff (A6 §17.2). A ZSM is a Teafair official covering one or more zones (zones are states), with one membership per tenant served. The active tenant decides which brand's book a screen shows. Navigation is built from the **live** role list in the JWT, re-read after each set_active_tenant.

5.2 Workspaces

Workspace	Roles	Primary tabs (proposal)
Field management	ZSM, TM, ASM	Today · Approvals (requisitions, financing above limit) · Holds (ZSM, §6) · Team · Inbox (A4 chat)
Street sales	ZSA, ASA	Beat (shops in my area or zone) · Trade orders · Monvelo (consent, supply days, requests) · Holds (ASA only) · Lenders (summary, §7.4)
Direct sales	DSM, DSA	Pickups · Orders · Links (A1 referral links). Not part of Monvelo.
Shop owner	RETAIL_SHOP_OWNER	My shop · Deliveries (read the code out) · Repayments · Credit (limits, consent, withdraw)
Monvelo agent	members of a monvelo_agents row (no tenant role)	Offers · My claims · Fund · Repayments · Exposure (§7) · Reconciliation
Tenant representation	CLIENT_SERVICE_MANAGER, LOGISTICS_MANAGER, TENANT_ADMIN	Contact reports · Catalogue · Stock · Dispatch (LM) · read-only book (TENANT_ADMIN). Mostly a web console concern.

Table 8. Role-based workspaces. A person can hold several; the switcher lists them.

5.3 Street recruitment and Monvelo initialisation (ZSA and ASA)

ZSAs and ASAs load Monvelo once per shop and per agent, then raise requests on supply days. Each step is one RPC or gateway. The consent and delivery codes go to the owner's verified phone, never to the street agent.

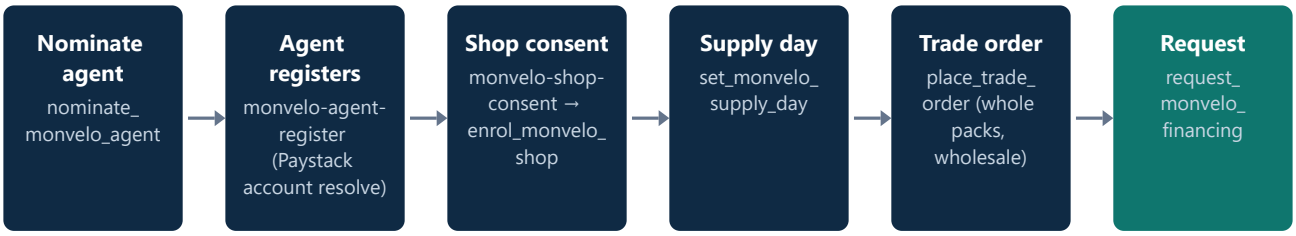


Figure 2. Initialisation and request sequence for a ZSA or ASA.

Step	Call	Screen behaviour
Nominate a POS agent the shop trusts	`nominate_monvelo_agent(p_idempotency_key uuid, p_shop_id uuid, p_name text, p_phone text, p_pos_network pos_network_enum)`	Store only the last four digits of the phone in local state after submit; the RPC keeps four digits too.
Owner consent (MV-SHARE-2026-10)	`gateway monvelo-shop-consent → enrol_monvelo_shop(p_idempotency_key uuid, p_challenge_id uuid, p_code text)`	Show the consent text in full (the WhatsApp template carries none). The owner reads the code to the agent, who types it in. A wrong code is a 422.
Supply day for an area	`set_monvelo_supply_day(p_idempotency_key uuid, p_area_id uuid, p_day_of_week integer, p_active boolean)`	A weekday toggle per area (p_day_of_week, p_active), limited to the caller's areas. Show the next supply dates in Lagos time.
Trade order	`place_trade_order(p_idempotency_key uuid, p_shop_id uuid, p_lines jsonb, p_territory_id uuid = NULL)`	Quantity steppers move in break-bulk packs (§8). Prices are wholesale and read-only.
Financing request	`request_monvelo_financing(p_idempotency_key uuid, p_order_id uuid)`	Result OFFERED (within the shop's limit) or AWAITING_APPROVAL (the TM approves). A raiser whose PAR30 is above 10% is refused, with a message.

SECTION 6

Monvelo Market-Maker Allowance UI

A claim blocked **only** by the ₦1,000,000 open exposure cap is held for 15 minutes instead of being refused, provided the agent's open exposure including this financing stays within ₦3,000,000. During the hold no other agent can claim the request. A market maker in scope (a ZSM whose reach covers the zone, or the area's ASA) may allow it with a reason or decline it. Approved 2026-11-02 (A6 §20; decisions 1A, 2A, 3A).



Figure 3. Hold lifecycle on the happy path. DECLINED returns OFFERED; no decision in 15 minutes is LAPSED (OFFERED).

6.1 Who sees what

Actor	Sees	Never sees
Agent member (claimant)	Claim reply {held: true, hold_id, expires_at, financing_id, reference, status, principal}; then a MONVELO_HOLD_DECIDED notice (allowed, declined or lapsed).	Who decided.
Market maker: ZSM in reach, or the area's ASA	The hold list and detail: the request, the shop's record and limits in this tenant, the blocks, within_limit, ready, and once decided their own name, time and reason.	The agent's name, id, phone, network, location and own figures (exposure, pledge left).
The request's raiser; any member of the held agent (R78)	Nothing. The hold is not listed, no notice is sent, and get or decide returns 42501.	The hold.
ZSA, TM, CSM, TENANT_ADMIN, LM	Nothing (42501 on the three RPCs).	The hold.

Table 9. Visibility (A6 §20.6, call 9, R78).

6.2 Component: HoldCard and the countdown

- **Source of time.** The countdown runs to the server's expires_at (timestamptz). The app computes a clock offset from the HTTP Date header of the list call (offset = serverNow − Date.now()) and renders expires_at − (Date.now() + offset), so a phone with a wrong clock still shows the right time left. It never extends locally.
- **Display.** mm:ss, monospaced digits, ticking each second. Amber below 5:00, red below 1:00. At 0:00 the card turns **Lapsed (awaiting sweep)**, the Allow and Decline buttons are disabled, and the list refreshes. The sweep runs every minute, and an allow after expires_at is refused as lapsed anyway (R69).
- **Status chips** from monvelo_claim_holds.status: HELD · ALLOWED · DECLINED · LAPSED. HELD cards sort first, then decided cards from the last 7 days (the RPC's order).

- **Lagos time** for every absolute time ("expires 14:32"), matching the WhatsApp notice text.
- **Accessibility.** Announce the remaining time at 5:00, 1:00 and lapse through an accessibility live region, not every second.

6.3 Component: readiness and credit badges

The view is pass or fail by design (call 9). It never shows the agent's raw exposure. Badges map one to one onto the returned fields.

Badge	Field	States	Copy (proposal)
Funding side ready	ready boolean	false while HELD; true once allowed	"Waiting for a market maker" / "Ready to fund"
Block	blocks text[]	EXPOSURE_CAP (the only value the CHECK allows)	"Over the ₦1,000,000 open exposure cap"
Within the allowance	within_limit boolean	pass (green) / fail (red); live while HELD, frozen once decided (R72)	"Within ₦3,000,000: yes" / "no — cannot be allowed"
Daily cap	none: never a hold	A daily-cap block is refused at claim time, so it never reaches this screen (decision 3A)	Explain in a help sheet: "The agent's own daily cap is set by Monvelo staff and is never overridden."
Shop record	shop_repaid_in_window, shop_repaid_late, shop_defaulted, shop_open, shop_limits	counts in this tenant; limits per brand	"Repaid on time 6 · late 1 · defaulted 0 · open 1"

Table 10. Readiness badges against the hold result columns.

> **PROTECTING THE PERSONAL DAILY CAP (CHOICE 3A)**
>
> Only the ₦1,000,000 exposure cap can be lifted. The agent's daily_cap and per-financing cap are set by Monvelo staff (set_monvelo_agent_caps) and stand. If within_limit is true but an allow is refused, the database re-ran every check (the daily cap included) under the agent's advisory lock and found a new block. The app then shows the P0001 text verbatim, and the hold stays HELD.

6.4 Component: the decision sheet

Control	Rule	Source
Reason text box	Required to Allow; trimmed length ≥ 10 and ≤ 1000 characters. Live counter "7 / 10 minimum". Allow stays disabled until valid. Optional for Decline.	22023 "give a reason of at least 10 characters to allow"; R77
Allow	Confirm sheet: "You are allowing this agent to fund ₦X for <shop>. You are accountable for this decision." Single tap, then a spinner. No retry on 422.	decide_monvelo_claim_hold(..., p_allow => true, p_reason)

Control	Rule	Source
Decline	Confirm sheet. The declined agent can never reclaim this request.	call 8
Idempotency	Generate the key when the sheet opens; reuse it for retries of that same decision only.	Spec A §7.2
Online only	Disabled offline with "Decisions need a connection: the hold expires in mm:ss".	the 15-minute window

Table 11. Decision sheet rules.

Outcomes the sheet must handle

Response	Meaning	UI
`{status: CLAIMED, hold_status: ALLOWED …}`	Allowed. The agent now has 15 minutes to pay.	Card → Allowed; toast "Allowed. The agent has been told to pay."
`{status: OFFERED, hold_status: DECLINED …}`	Declined; the request is open to other agents.	Card → Declined.
`P0001 "this hold has already been decided"`	Another market maker acted first.	Refresh; show who decided only if it was you.
`P0001 "this hold has lapsed"`	15 minutes passed.	Card → Lapsed.
`P0001 with a refusal sentence`	A re-run check failed (daily cap, pledge, freeze …).	Show the sentence; the hold stays HELD.
`42501 "this hold is not yours to decide"`	Out of scope, the raiser, or a member of the agent.	Remove the card; neutral message.

6.5 Four-eyes segregation of duties (choice 2A)

The rule: **whoever raised the request (`monvelo_financings.raised_by`) can never allow or decline its hold**, and neither can anyone with a membership row in the held agent, ACTIVE or REVOKED (R78). The database enforces it three times. The raiser is excluded from the market makers notified (monvelo_hold_market_makers), excluded from the list (monvelo_claim_hold_rows), and refused by decide_monvelo_claim_hold with 42501.

- **The client mirrors the rule and never replaces it.** The hold list comes from the server already filtered, so the app never needs to know who the raiser was, and must not try to compute it.
- **Raiser-side UX.** An ASA who raised a request that is now held sees on their own request: "Waiting for another market maker (you raised this request)". The status comes from monvelo_order_financing_status ; no hold id is exposed.
- **When nobody else is in scope**, the hold can only lapse. The app does not offer an escalation that would bypass this.
- **Testing.** Keep a UI test that signs in as the raiser and asserts the hold is absent, alongside pgTAP 066, which proves the server side.

6.6 Hold result contract

Column	Type
hold_id	uuid
financing_reference	text
shop_name	text
shop_code	text
area_name	text
principal	numeric(15,2)
brand_lines	jsonb
expires_at	timestamptz
ready	boolean
blocks	text[]
within_limit	boolean
shop_repaid_in_window	integer
shop_repaid_late	integer
shop_defaulted	integer
shop_open	integer
shop_limits	jsonb
status	text
decided_by_name	text
decided_at	timestamptz
reason	text

Table 12. list_monvelo_claim_holds() and get_monvelo_claim_hold(p_hold_id) return these columns (parsed from the migrations).

SECTION 7

Agent Exposure and Reconciliation Views

7.1 How open exposure is computed (A6 §19.4.1, §20 call 4)

Financing status	Counts toward exposure	Why
HELD	principal	Two holds cannot together pass ₦3,000,000 (call 4).
CLAIMED (by claimed_by_agent_id)	principal	The agent has committed to pay.
FUNDED (by funder_agent_id)	principal	Money is out, stock not yet delivered.
DELIVERED, DEFAULTED_WITH_LATE_CHARGE	**least(outstanding, principal)**	Part repayments free room; the late charge never consumes room.
REFUND_DUE	nothing	R63: "the central truth is funded order fulfilment". Room frees at the sweep; only the pledge waits for the refund.
OFFERED, REPAID_*, EXPIRED, CANCELLED	nothing	No agent owns it, or it is closed.

Table 13. Exposure is summed across every tenant the agent funds.

The ceiling is one platform constant (monvelo_open_exposure_ceiling() = ₦1,000,000); the allowance ceiling is monvelo_allowance_ceiling() = ₦3,000,000. Both are changed by migration only. The claim refusal text is built from the constant: "this request would take your open exposure above ₦1,000,000".

7.2 The exposure meter (component spec)

- **Audience:** members of a Monvelo agent, for their own agent only. Never market makers, tenants or ZSAs.
- **Visual:** a horizontal meter from ₦0 to ₦1,000,000, with a marker for the ₦3,000,000 allowance zone shown as a dashed extension. Segments are stacked by status (HELD, CLAIMED, FUNDED, DELIVERED/DEFAULTED at the least of outstanding and principal), each with a legend and amount.
- **Headroom line:** "₦X left under the cap". At or above the cap: "New claims above this need a market maker's allowance, up to ₦3,000,000".
- **Daily cap:** a second, separate meter for today's funding against daily_cap (Lagos day, REFUND_DUE excluded). It is never merged with exposure, because it can never be allowed past.
- **Freshness:** money class, never stale. Refresh on focus and after every claim, funding, repayment or notice. Show "as of hh:mm" on any cached value.

7.3 Gap G1: no read path for exposure

FINDING G1 — BLOCKING FOR THE METER

monvelo_agent_open_exposure(p_agent_id), monvelo_open_exposure_ceiling() and monvelo_allowance_ceiling() hold no EXECUTE grant for authenticated (verified from the grants), and no granted RPC returns them. The agent's members cannot compute it client-side either: the lender columns of monvelo_financings are outside the column grant (R9), and HELD holds are unreadable (monvelo_claim_holds has no policy).

Recommendation: a read-only SECURITY DEFINER RPC, for example get_monvelo_agent_exposure(p_agent_id uuid), granted to authenticated. It checks live that the caller is an ACTIVE member of the agent and returns {open_exposure, ceiling, allowance_ceiling, by_status[], funded_today, daily_cap}. This needs a migration and a pgTAP file, so it is a backend change for the owner to approve, not part of this report.

7.4 Weekly lender reconciliation (get_lender_reconciliation_summary)

get_lender_reconciliation_summary(p_weeks integer default 12) returns one row per agent and **Lagos week of `funded_at`**. Weeks are date_trunc('week', funded_at at time zone 'Africa/Lagos'), so each week starts on a **Monday** in Lagos. The window runs from this week back p_weeks − 1 weeks; a p_weeks outside 1–52 is 22023. Every figure belongs to its funding week.

Column	Type
agent_id	uuid
agent_name	text
week_start	date
capital_funded	numeric(15,2)
outstanding	numeric(15,2)
repaid	numeric(15,2)
refunded	numeric(15,2)
rebates_owed	numeric(15,2)
rebates_paid	numeric(15,2)
mv_references	text[]

Reader	Rows	App surface
ACTIVE member of an agent	that agent's rows across every tenant (wins over any ZSA/ASA role)	Agent workspace → Reconciliation
ZSA (active tenant)	financings in the tenant whose area lies in the ZSA's zone	Street sales → Lenders
ASA (active tenant)	financings in the tenant in the ASA's area	Street sales → Lenders

Reader	Rows	App surface
Everyone else (TM, ZSM, CSM, TENANT_ADMIN, LM, anon)	42501	Hidden

Table 14. Readers, checked live. The ZSA/ASA reading is a deliberate exception to §16.2.2 (owner, 2026-11-02).

Screen spec

- **Week selector:** 4, 12 (default) or 26 weeks. Week labels read "Mon 26 Oct – Sun 1 Nov".
- **Per-week card:** capital funded, outstanding, repaid, refunded, rebates owed and paid. rebates_paid reads ₦0 until Step 5 ships payouts, so label it "pending payout run".
- **MV references** in a collapsible list (MV-XXXXXXXX-n), copyable, for matching bank statements.
- **Anonymised by contract:** the output never names a shop, owner, phone, brand, tenant or place, and the app adds nothing from other sources. For ZSA/ASA readers, agent_name is the registered business name; group by agent within each week.
- **Totals row** computed client-side with decimal arithmetic from the string values; never floats.

SECTION 8

Trade Orders, Packs and Owner Codes

8.1 Break-bulk in the app

Prices are stored **per unit**: unit_price is retail and wholesale_price is wholesale. carton_units and break_bulk_units define the packs; the generated columns carton_wholesale_price and break_bulk_wholesale_price give pack prices. **Every app sale (FIELD_SALES, RETAIL, pickups) is wholesale and in whole packs**. The table triggers refuse anything else with P0001, so the UI should make the wrong quantity impossible rather than wait for the refusal.

SKU	Carton	Break-bulk pack	Wholesale / unit	Pack price	Carton price
PURERIGIN-COCONUT-OIL-200ML	12	3 (quarter)	₦4,000	₦12,000	₦48,000
PURERIGIN-COCONUT-OIL-100ML	24	6 (quarter)	₦2,500	₦15,000	₦60,000

Table 15. Teafair's house brand as seeded (COSMETICS, NAFDAC LG-IKJ-02-2134).

- **Stepper:** steps by break_bulk_units (else carton_units, else 1). It shows "3 packs × 3 = 9 bottles" and the line total at break_bulk_wholesale_price.
- **Stock:** a TF001 reply carries {sku_code, available, requested}. Offer "reduce to N packs".

8.2 Delivery and repayment codes

The shop owner's 6-digit codes go over WhatsApp to the owner's verified phone. The deliverer (a holder of a fulfilment_delivery_path) or the recording agent member types in the code the owner reads out. A wrong, expired or locked code is a 422. Delivery is refused from funded_at + 23 h; the money sweep moves the financing to REFUND_DUE at that same instant.

Flow	Start	Confirm	UI notes
Delivery	gateway monvelo-confirm-delivery → start_monvelo_delivery	`confirm_monvelo_delivery(p_idempotency_key uuid, p_challenge_id uuid, p_code text)`	Show the 23-hour cutoff as a countdown from funded_at; a fresh idempotency key for every code entry.
Repayment	gateway monvelo-confirm-repayment → record_monvelo_repayment	`confirm_monvelo_repayment(p_idempotency_key uuid, p_challenge_id uuid, p_code text)`	The amount is capped at outstanding. Only the recording member may confirm. A PENDING repayment expires at 24 h.
Owner rejects	—	`reject_monvelo_repayment(p_idempotency_key uuid, p_repayment_id uuid)`	Owner workspace: "This payment did not happen". Raises a flag and a HIGH ticket.

SECTION 9

Design System and Accessibility

The app uses NativeWind with the teafair-* tokens from FIGMA.md (locked 2026-10-07). Stock palette classes are never used for brand elements. The slate, teal and navy palette of this PDF is a documentation palette only; it is not the app's.

Token	Hex	Use in the Monvelo screens
teafair-emerald	#4CAF50	Primary actions (Allow, Fund, Confirm code)
teafair-lime	#8BC34A	Pass badges ("within ₦3,000,000: yes", "Ready to fund")
teafair-forest	#2E7D32	Headers, the meter's funded segment
teafair-black	#111111	Primary text
teafair-surface	#F5F7F6	Cards, inputs
teafair-darkSurfaceEnd	#1A2E1B	Dark-mode surface gradient end

Table 16. Brand tokens (FIGMA.md). Warning and error tones need tokens added in Spec B; none exist yet.

- **Gap G6:** FIGMA.md defines no warning or error colours. The countdown's amber and red, and the fail badge, need teafair-* tokens agreed in Spec B. Until then they must not fall back to stock classes.
- **Touch targets** at least 48 dp. Money in tabular figures. The naira sign is rendered as text, not an icon.
- **Language:** plain English first. Pidgin and Yoruba copy are a later localisation pass; server messages arrive in English.

SECTION 10

Audit Findings and Gaps

ID	Severity	Finding	Recommendation
G1	High	No granted RPC returns an agent's open exposure, the ceilings or today's funding against daily_cap.	Add get_monvelo_agent_exposure (read-only, member-only) with pgTAP; owner approval needed.
G2	High	The login method is unspecified in Spec A; the brief's password login for field roles conflicts with the hardened phone-only route.	Decide in Spec B (§4.2 proposal).
G3	Medium	The claim is a direct RPC; A6 §20.9 left open whether the held reply needs a gateway. The app must branch on held in the RPC result.	Keep it direct; document held in the Spec B API layer.
G4	Medium	Notices (MONVELO_HOLD, MONVELO_HOLD_DECIDED) are notifications rows. Push delivery needs register_device push tokens and a sender, which do not exist yet.	Spec B: Realtime on notifications while foregrounded; push sender in a later addendum.
G5	Medium	Step 5 (rebate payouts) is not built; rebates_paid is always 0.	Label it in the UI; no client workaround.
G6	Low	No warning or error colour tokens in FIGMA.md.	Add them with Spec B.
G7	Low	Nothing after 20261015130200 is on the remote; a client built now runs against the local stack only.	Plan the deploy order (D1 → A3/A4 → A5 → pricing → auth → A6) before any device testing against the remote.

Table 17. Findings ranked by severity.

SECTION 11

Appendix A — Mobile RPC Contracts

Signatures are the latest create or replace function in migration order. "Callers" are the roles holding EXECUTE after every grant and revoke. service_role means only a gateway can reach the function; authenticated means the app calls it with the user's JWT, and the function itself checks the role and scope live.

11.1 Session and identity

Function	Callers	Returns
`set_active_tenant(p_idempotency_key uuid, p_tenant_id uuid)`	authenticated	jsonb
`register_device(p_idempotency_key uuid, p_hardware_id text, p_device_model text, p_push_token text)`	authenticated	jsonb
`verify_pin(p_pin text)`	authenticated	public.pin_check

11.2 Street agents and recruitment

Function	Callers	Returns
`nominate_monvelo_agent(p_idempotency_key uuid, p_shop_id uuid, p_name text, p_phone text, p_pos_network pos_network_enum)`	authenticated	jsonb
`start_monvelo_consent(p_idempotency_key uuid, p_gateway_proof text, p_shop_id uuid, p_area_id uuid)`	authenticated	jsonb
`enrol_monvelo_shop(p_idempotency_key uuid, p_challenge_id uuid, p_code text)`	authenticated	jsonb
`withdraw_monvelo_shop_consent(p_idempotency_key uuid, p_shop_id uuid)`	authenticated	jsonb
`set_monvelo_supply_day(p_idempotency_key uuid, p_area_id uuid, p_day_of_week integer, p_active boolean)`	authenticated, service_role	jsonb
`place_trade_order(p_idempotency_key uuid, p_shop_id uuid, p_lines jsonb, p_territory_id uuid = NULL)`	authenticated	jsonb
`request_monvelo_financing(p_idempotency_key uuid, p_order_id uuid)`	authenticated	jsonb
`approve_monvelo_financing(p_idempotency_key uuid, p_financing_id uuid)`	authenticated	jsonb
`cancel_monvelo_financing(p_idempotency_key uuid, p_financing_id uuid, p_reason text)`	authenticated	jsonb
`monvelo_order_financing_status(p_order_ids uuid[])`	authenticated	table (see below)

monvelo_order_financing_status → result columns

Column	Type
`order_id`	`uuid`
`financing_state`	`text`

Column	Type
financing_id	uuid
reference	text
principal	numeric

11.3 Monvelo agents

Function	Callers	Returns
pledge_monvelo_funds(p_idempotency_key uuid, p_agent_id uuid, p_area_id uuid, p_supply_date date, p_amount numeric)	authenticated, service_role	jsonb
monvelo_supply_days_near(p_agent_id uuid, p_days integer = 7)	authenticated, service_role	table (see below)
monvelo_open_offers(p_agent_id uuid)	authenticated	table (see below)
claim_monvelo_financing(p_idempotency_key uuid, p_financing_id uuid, p_agent_id uuid)	authenticated	jsonb
start_monvelo_funding(p_idempotency_key uuid, p_financing_id uuid, p_agent_id uuid)	authenticated	jsonb
record_monvelo_repayment(p_idempotency_key uuid, p_gateway_proof text, p_financing_id uuid, p_agent_id uuid, p_amount numeric)	authenticated	jsonb
confirm_monvelo_repayment(p_idempotency_key uuid, p_challenge_id uuid, p_code text)	authenticated	jsonb

monvelo_supply_days_near → result columns

Column	Type
area_id	uuid
area_name	text
supply_date	date
shop_count	integer

monvelo_open_offers → result columns

Column	Type
financing_id	uuid
reference	text
shop_name	text
shop_code	text
area_name	text
principal	numeric
distance_m	integer
supply_date	date

Column	Type
preferred_until	timestamptz

11.4 Market makers

Function	Callers	Returns
list_monvelo_claim_holds()	authenticated	table (see below)
get_monvelo_claim_hold(p_hold_id uuid)	authenticated	table (see below)
decide_monvelo_claim_hold(p_idempotency_key uuid, p_hold_id uuid, p_allow boolean, p_reason text)	authenticated	jsonb

list_monvelo_claim_holds → result columns

Column	Type
hold_id	uuid
financing_reference	text
shop_name	text
shop_code	text
area_name	text
principal	numeric(15,2)
brand_lines	jsonb
expires_at	timestamptz
ready	boolean
blocks	text[]
within_limit	boolean
shop_repaid_in_window	integer
shop_repaid_late	integer
shop_defaulted	integer
shop_open	integer
shop_limits	jsonb
status	text
decided_by_name	text
decided_at	timestamptz
reason	text

get_monvelo_claim_hold → result columns

Column	Type
hold_id	uuid

Column	Type
financing_reference	text
shop_name	text
shop_code	text
area_name	text
principal	numeric(15,2)
brand_lines	jsonb
expires_at	timestamptz
ready	boolean
blocks	text[]
within_limit	boolean
shop_repaid_in_window	integer
shop_repaid_late	integer
shop_defaulted	integer
shop_open	integer
shop_limits	jsonb
status	text
decided_by_name	text
decided_at	timestamptz
reason	text

11.5 Delivery and owners

Function	Callers	Returns
dispatch_monvelo_financing(p_idempotency_key uuid, p_financing_id uuid, p_tracking_reference text)	authenticated	jsonb
start_monvelo_delivery(p_idempotency_key uuid, p_gateway_proof text, p_financing_id uuid)	authenticated	jsonb
confirm_monvelo_delivery(p_idempotency_key uuid, p_challenge_id uuid, p_code text)	authenticated	jsonb
reject_monvelo_repayment(p_idempotency_key uuid, p_repayment_id uuid)	authenticated	jsonb

11.6 Reconciliation

Function	Callers	Returns
get_lender_reconciliation_summary(p_weeks integer = 12)	authenticated	table (see below)

get_lender_reconciliation_summary → result columns

Column	Type
agent_id	uuid
agent_name	text
week_start	date
capital_funded	numeric(15,2)
outstanding	numeric(15,2)
repaid	numeric(15,2)
refunded	numeric(15,2)
rebates_owed	numeric(15,2)
rebates_paid	numeric(15,2)
mv_references	text[]

SECTION 12

Appendix B — Enumerations, Statuses and Jobs

12.1 Enumerations and status sets

Name	Values (in definition order)
tenant_role_enum	ZSM, TM, ASM, DSM, DSA, POS_AGENT, RETAIL_SHOP_OWNER, ZSA, ASA, CLIENT_SERVICE_MANAGER, TENANT_ADMIN, LOGISTICS_MANAGER
platform_role_enum	PLATFORM_SUPER_ADMIN, MONVELO_OPERATOR, MONVELO_FINANCE
order_channel_enum	ONLINE, FIELD_SALES, RETAIL
pos_network_enum	MONIEPOINT, OPAY, PALMPAY
kyc_status_enum	UNVERIFIED, PENDING, VERIFIED, REJECTED
monvelo_financings.status (CHECK)	REQUESTED, AWAITING_APPROVAL, OFFERED, HELD, CLAIMED, FUNDED, DELIVERED, REPAID_WITHIN_WINDOW, DEFAULTED_WITH_LATE_CHARGE, REPAID_LATE, EXPIRED, CANCELLED, REFUND_DUE
monvelo_claim_holds.status (CHECK)	HELD, ALLOWED, DECLINED, LAPSED
monvelo_repayments.status (CHECK)	PENDING, CONFIRMED, REJECTED, EXPIRED
monvelo_tenant_ledger_entries.entry_type (CHECK)	FUNDED_GROSS, REBATE, FEE, REFUND, REMITTANCE

12.2 Scheduled jobs the app depends on

Job	Schedule (UTC)	Defined in
stock-reservation-sweep	*/15 * * * *	20261029130150_stock_reservations.sql
monvelo-offer-sweep	* * * * *	20261029130300_monvelo_claims.sql
monvelo-money-sweep	*/5 * * * *	20261031120400_monvelo_money_sweep.sql

Table 18. The hold lapses within a minute of expires_at; REFUND_DUE and expired repayments within five.

12.3 Gateways used by the app

auth-verify-claims · contact-report-upload · monvelo-agent-register · monvelo-confirm-delivery · monvelo-confirm-repayment · monvelo-fund · monvelo-shop-consent · order-delivery-confirm · order-delivery-photo · order-delivery-pin · order-dispatch · order-dispute-evidence · otp-issue · otp-verify · support-staff-attachment · web-order-status